

Security+ 2.4 · Replay Attacks

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.4 — Replay Attacks (5:45)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Replay: capture the handshake/token and RESEND it to authenticate again. Pass-the-hash: use the password HASH directly as an NTLM authenticator (Mimikatz + PsExec) — lateral movement. Session hijacking: steal an active session cookie (via XSS or on-path) and impersonate the user. Defenses: nonce/timestamp, TLS, HttpOnly cookie, session token with expiration.

High-Yield Core Concepts Tested on Exam

- Replay: resends the captured 'handshake' — defense: nonce/timestamp
- Pass-the-hash: uses THE HASH (not the password) — NTLM is vulnerable, Kerberos less so
- Session hijacking: steals the cookie — HttpOnly + HTTPS mitigates
- Pass-the-hash enables lateral movement across systems
- Session tokens must have expiration to limit hijacking window

Exam Tips & Classic Scenarios

- 'reuses captured authentication data' = replay attack
- 'uses an NTLM hash to authenticate' = pass-the-hash

Typical Exam Scenario: Scenario: 'attacker captures the NTLM hash from memory and uses it to log into other systems' = pass-the-hash.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.4 — Replay Attacks)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **KERBEROS:** Default Active Directory authentication protocol based on symmetric ticket granting issued by the Key Distribution Center (KDC: AS and TGS), preventing cleartext credentials on the wire.
- **NTLM:** NT LAN Manager: Legacy Microsoft challenge/response authentication protocol vulnerable to Pass-the-Hash and Relay attacks; must be deprecated in favor of Kerberos.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Attacker positions between two parties and intercepts/alters communication. This is:

- A)** On-path attack (MITM)
- B)** Denial of service
- C)** SQL injection
- D)** Brute force

2. Corporate scenario (Replay Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Replay: resends the captured 'handshake' — defense: nonce/timestamp'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Replay: resends the captured 'handshake' — defense: nonce/timestamp...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

3. Corporate scenario (Replay Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Pass-the-hash: uses THE HASH (not the password) — NTLM is vulnerable, Kerberos less so.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Pass-the-hash: uses THE HASH (not the password) — NTLM is vulnerable, Kerberos less so...
- D)** Allow shared access among administrators with generic credentials

4. Corporate scenario (Replay Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Session hijacking: steals cookie — HttpOnly + HTTPS mitigates'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Session hijacking: steals cookie — HttpOnly + HTTPS mitigates...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (Replay Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'reuses captured authentication data' = replay attack'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'reuses captured authentication data' = replay attack...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Replay Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'uses an NTLM hash to authenticate' = pass-the-hash. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'uses an NTLM hash to authenticate' = pass-the-hash
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Replay Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Scenario: 'attacker captures the NTLM hash from memory and uses it to log into other systems' = pass-the-hash.' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Scenario: 'attacker captures the NTLM hash from memory and uses it to log into other...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

8. Corporate scenario (Replay Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Replay: resends the captured 'handshake' — defense: nonce/timestamp'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Replay: resends the captured 'handshake' — defense: nonce/timestamp...

9. Corporate scenario (Replay Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Pass-the-hash: uses THE HASH (not the password) — NTLM is vulnerable, Kerberos less so'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Pass-the-hash: uses THE HASH (not the password) — NTLM is vulnerable, Kerberos less so
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Replay Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Session hijacking: steals cookie — HttpOnly + HTTPS mitigates'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Session hijacking: steals cookie — HttpOnly + HTTPS mitigates...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — On-path attack (MITM).

✓ **Why it's correct:** The correct answer is 'On-path attack (MITM)'. An on-path attack, also known as man-in-the-middle (MITM), occurs when an attacker secretly positions between two parties who believe they are communicating directly. The attacker can intercept, alter, or relay messages without the parties noticing. The statement describes exactly this scenario: the attacker positions between two parties and intercepts/alters communication. CompTIA uses the term 'on-path attack' as a synonym for MITM, making it the precise answer for the description.

✗ **Why the others are wrong:**

- *Denial of service:* Denial of service (DoS) is an attack that aims to make a service, network, or system unavailable to legitimate users, usually by overwhelming it with malicious traffic. It does not involve interception or alteration of communication between two parties. The goal is to disrupt the service, not to spy on or modify data. Therefore, DoS does not apply to the described scenario.
- *SQL injection:* SQL injection is an attack technique that exploits vulnerabilities in web applications that do not properly validate user input, allowing execution of malicious SQL commands in the database. It has no relation to intercepting communication between two parties. It is an injection attack, not a man-in-the-middle positioning. Therefore, SQL injection is incorrect.
- *Brute force:* Brute force is an attack method that consists of exhaustively trying all possible combinations of passwords or keys to gain unauthorized access. It does not involve interception or alteration of traffic. It is a guessing attack, not a positioning between parties. Therefore, brute force is not the correct answer.

2) A — Implement the corresponding solution: Replay: resends the captured 'handshake' — defense: nonce/timestamp....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Replay Attacks): Replay: resends the captured 'handshake' — defense: nonce/timestamp. A replay attack involves capturing and retransmitting valid data to deceive a system; defenses include using nonces (random numbers used once) or timestamps to ensure freshness.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

3) C — Implement the corresponding solution: Pass-the-hash: uses THE HASH (not the password) — NTLM is vulnerable, Kerberos less so....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Replay Attacks): Pass-the-hash: uses THE HASH (not the password) — NTLM is vulnerable, Kerberos less so. Pass-the-hash is an attack where the attacker captures a password hash and uses it to authenticate without knowing the plaintext password. NTLM is particularly vulnerable because it uses the hash directly in authentication, while Kerberos is more resistant due

to its ticket-based system and mutual authentication.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) B — Implement the corresponding solution: Session hijacking: steals cookie — HttpOnly + HTTPS mitigates....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Replay Attacks): Session hijacking: steals cookie — HttpOnly + HTTPS mitigates. The HttpOnly flag prevents client-side scripts from accessing the cookie, mitigating XSS-based session theft, while HTTPS encrypts the cookie in transit, preventing interception. Together they directly address the session hijacking vector described.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) B — Implement the corresponding solution: 'reuses captured authentication data' = replay attack....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Replay Attacks): 'reuses captured authentication data' = replay attack. A replay attack occurs when an attacker intercepts and retransmits valid authentication data to gain unauthorized access. Defenses include timestamps, nonces, and session tokens to ensure each authentication attempt is unique.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) C — Implement the corresponding solution: 'uses an NTLM hash to authenticate' = pass-the-hash.

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Replay Attacks): 'uses an NTLM hash to authenticate' = pass-the-hash. This attack leverages captured NTLM hashes to authenticate without knowing the plaintext password, exploiting weaknesses in NTLM authentication.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: Scenario: 'attacker captures the NTLM hash from memory and uses it to log into other....'

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Replay Attacks): Scenario: 'attacker captures the NTLM hash from memory and uses it to log into other systems' = pass-the-hash. Pass-the-hash is a technique where an attacker uses a captured NTLM hash to authenticate without knowing the plaintext password. The correct action is to implement the corresponding mitigation (e.g., credential Guard, restricted admin mode, least privilege).

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) D — Implement the corresponding solution: Replay: resends the captured 'handshake' — defense: nonce/timestamp....'

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Replay Attacks): Replay: resends the captured 'handshake' — defense: nonce/timestamp. A replay attack occurs when an attacker captures a valid data transmission and fraudulently repeats or delays it. Defenses include using nonces (random numbers used once) and timestamps to ensure freshness and prevent replay.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are

administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) C — Implement the corresponding solution: Pass-the-hash: uses THE HASH (not the password) — NTLM is vulnerable, Kerberos less so.

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Replay Attacks): Pass-the-hash: uses THE HASH (not the password) — NTLM is vulnerable, Kerberos less so. This highlights that NTLM authentication is susceptible to pass-the-hash attacks, while Kerberos provides stronger protections.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) B — Implement the corresponding solution: Session hijacking: steals cookie — HttpOnly + HTTPS mitigates....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Replay Attacks): Session hijacking: steals cookie — HttpOnly + HTTPS mitigates. HttpOnly prevents client-side scripts from accessing cookies, and HTTPS encrypts data in transit, mitigating session hijacking.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.